# Response to Reviewer 2

*Enhancing Consent Policy Privacy in Blockchain-Based Healthcare Data Sharing*

---

**Working draft.** Page and line references will be added after the revised manuscript reaches final pagination.

**Comments 1:** *The abstract is clear and presents the manuscript; however, it is too long (235 words). It must be less than 200 words.*

**Response 1:** The abstract has been rewritten and shortened to under 200 words. It also reflects the re-measured padding overhead of the revised system.

**Location in the revised manuscript:** Abstract.

> In blockchain-based healthcare data sharing, consent policies are expected to be enforced verifiably and auditably, but public-chain transparency may expose sensitive policy information through on-chain representations, verification interfaces, and execution artifacts. Existing privacy-preserving solutions mainly protect data contents, identities, or transactions, not the governing consent policies. We propose the Trusted Proof Service-assisted Zero-Knowledge Policy Interpreter (TPS-ZKPI), which lets an on-chain verifier check authorization decisions while limiting leakage about policy content, identity, and structure. TPS-ZKPI combines fixed-length policy encoding, a reusable zero-knowledge policy interpreter, commitment-based policy binding, and public-chain transcript normalization. We evaluate TPS-ZKPI on Polygon Amoy against metadata-only public-chain adversaries with supervised and unsupervised inference attacks. Under a multi-seed leakage criterion, no attack recovers hidden policy information reproducibly above chance; a paired ablation attributes the gas-channel protection to the gas padding of transcript normalization, at an overhead of about 46% on access and 38% on commit gas.

**Comments 2:** *Some of the keywords are wrong, such as "policy privacy" – 4 times in the text and "data use ontology" – 7 times.*

**Response 2:** We understood the comment to mean that the keywords should be the terms the manuscript actually uses, and we revised them accordingly. "policy privacy" is replaced by "consent policy privacy," the phrase of the title, which the Introduction and the Problem section use to name the umbrella objective that the three evaluated objectives (Policy Content Hiding, Policy Indistinguishability, Structure and Parameter Privacy) operationalize; "data use ontology" is written as the standard's name and acronym, "Data Use Ontology (DUO)," as in the Background; "zero-knowledge proof" is given in the plural form used throughout; and "metadata leakage," the manuscript's central concern, is added.

**Location in the revised manuscript:** Keywords.

> blockchain; consent policy privacy; zero-knowledge proofs; Data Use Ontology (DUO); healthcare data sharing; metadata leakage

**Comments 3:** *The introduction correctly outlines the issues. However, rows 123–131 point to old sources and methods of encryption. It raises the question "why?" – do the authors not know the newest or do they not want to use the newest; why do the authors not comment on the newest solutions?*

**Response 3:** The passage (the first paragraph of the Background section in the submitted version) introduced CP-ABE and PRE through their original constructions. We kept those two citations, because the later systems inherit their trust and disclosure properties and that is what the paragraph needs, but we now also cite the current blockchain healthcare designs built on them—PRE-based sharing of medical records and IoMT data (Pei et al., 2024; Zhou et al., 2024) and CP-ABE variants with hidden policies and attributes, distributed key generation, or multi-authority hierarchies (Yang and Liu, 2024; Ding et al., 2026; Wu et al., 2023)—and we state explicitly why the original constructions remain the reference point. The Related Work section discusses the hidden-policy variants and the recent self-sovereign-identity and zero-knowledge authentication work in the same spirit (see also the responses to Reviewer 3, Comment 5, and to Comment 10 below).

**Location in the revised manuscript:** Section "Background," subsection "Cryptographic Access Control in Blockchain Healthcare," first paragraph.

> Both primitives remain the building blocks of current blockchain healthcare designs: recent schemes combine PRE with on-chain records to delegate access to medical records and IoMT data, and CP-ABE variants with hidden policies and attributes, distributed key generation, or multi-authority hierarchies address the exposure of the access structure itself. We cite the original constructions because the later systems inherit their trust and disclosure properties, which is what matters for this paper: these primitives establish who may obtain the data, and how they relate to *policy* confidentiality on a public chain is discussed in the Related Work section.

**Comments 4:** *There is so much empty space on page 6, page 20, and page 25 because of the wrong position of Table 2, Table 9, and Table 12.*

**Response 4:** The gaps were caused by forcing every float to its source position (`[H]`), which pushes a large table to the next page and leaves the preceding page unfilled. All tables and figures now use the standard `[htbp]` placement, so LaTeX fills each page and floats a large table only when it does not fit. We checked the recompiled manuscript page by page: no page other than the last ends with unused space. Two of the three tables mentioned were also restructured in the revision (the corpus table now lists the revised corpus; the cost table gained a companion scaling table), which further reduced their height.

**Location in the revised manuscript:** All table and figure environments.

**Comments 5:** *The titles of tables and figures are very long. For example, Figure 1 has a 4-row title and Table 12 a 6-row title.*

**Response 5:** We shortened every caption to one or two sentences that name what is shown, and moved the explanatory material into the body text next to the first reference. For the two examples: the workflow figure's caption is now "TPS-assisted policy-compliance workflow (steps are described in the text)," with the step numbering explained in the Overview paragraph; the ablation table's caption is now two lines, with the selection rule for its rows and the reading of $\Delta_{\text{leak}}$ stated in the ablation section. The captions of the corpus, PCH, SPP, PI, clustering, related-work, and cost tables and of the two result figures were shortened in the same way.

**Location in the revised manuscript:** Captions of Figures 1, 2, and 3 and of all result tables.

> TPS-assisted policy-compliance workflow (steps are described in the text). [...] Gas-padding ablation on Polygon Amoy: B1 (no padding) versus B2 (deployed randomized padding) on the same 1119-execution subset; supervised rows are the largest-signal contrasts per experiment (random-forest AUC).

**Comments 6:** *On row 681 there is a formula in the text. This is not acceptable. Follow the proper format of formulas.*

**Response 6:** Row 681 of the submitted manuscript belonged to the PCH results paragraph, which reported per-task statistics as inline formulas of the form $\mathrm{AUC}_{\mathrm{mean}} = 0.561 \pm 0.053$. We removed inline formulas from the results prose of the PCH, SPP, and PI sections: statistics are now stated in words with the numeric values ("mean AUC 0.667 with 53% of seeds significant"), and the full figures live in the tables. The remaining displayed formulas are the definitions in the Design and Methodology sections and the paired leakage metric of the ablation, which is now a numbered equation.

**Location in the revised manuscript:** Section "Privacy Evaluation," subsections "Policy Content Hiding," "Policy Indistinguishability," "Structure & Parameter Privacy," and "Ablation" (Equation for $\Delta_{\mathrm{leak}}$).

> Chapter ch5 (diseases of the nervous system) meets both legs: mean AUC 0.667 with 53% of seeds significant. We report it as a FAIL of the criterion and examine below what the classifier separates.

**Comments 7:** *The opinion of the authors about the results is very short. The conclusions in Part 6 are almost missing.*

**Response 7:** The Conclusion has been rewritten as four paragraphs: what the revised construction contributes and which soundness gaps it closes; what the evaluation shows and what the ablation teaches about the un-padded channel; the limitations (trust in the TPS, the supported policy class, the unmodeled channels, the criterion's false-positive rate); and three directions that follow from those limitations. The Discussion likewise opens with the authors' reading of the results, including the two criterion failures and why we report rather than absorb them, before turning to the trust model.

**Location in the revised manuscript:** Section "Conclusion" (entire section); Section "Discussion," first paragraph.

> The evaluation shows what such a design can and cannot promise. On a live testnet corpus, a supervised attacker with policy-disjoint training data and an unsupervised clustering attacker recover neither policy content, nor policy identity, nor structure and parameters from the normalized transcript beyond what the padding's own random draws produce, and the paired ablation shows that the padding is what removes the last policy-correlated gas signal. The ablation also delivers a cautionary result: the un-padded channel it exposes is not the policy logic, which the fixed circuit already hides, but the byte-level pricing of one public transaction argument—a reminder that on a public chain any deterministic encoding difference that correlates with the policy is a channel, and that the defense must cover the class rather than the instances one anticipated.

**Comments 8:** *The English language looks quite good. The title and abstract reflect the content.*

**Response 8:** We thank the reviewer. The title is unchanged; the abstract was shortened and updated as described under Comment 1.

**Comments 9:** *The discussion and conclusion summarize the proposed idea. However, there is a repetition of the same conclusion in the abstract, discussion, and conclusion. This repetition of the same information should be avoided.*

**Response 9:** The three texts now serve different purposes. The abstract states the result and the overhead figures once. The Discussion interprets the results—the scope of the claim, the two criterion failures and their origin, the cost of padding, the trust model, and the attribute-origin guarantee—without restating the abstract. The Conclusion no longer repeats the numbers; it summarizes the contribution, the meaning of the results (including the cautionary finding of the ablation), the limitations, and the directions that follow.

**Location in the revised manuscript:** Abstract; Section "Discussion"; Section "Conclusion."

**Comments 10:** *Many of the references are old [7, 8, 10, 14, 15, 16, 17, 18, 19, 21, 23, 24, 25, 26, 27, 30, 31]. Some of them do not follow the proper format. I offer the authors to find newer sources and replace these old sources.*

**Response 10:** We reviewed each of the cited entries and took two actions.

**Newer sources.** Seven references from 2024–2026 were added and are now cited alongside the older ones wherever the text relies on them: PRE-based blockchain sharing of medical records and IoMT data (Pei et al., *Computer Networks*, 2024; Zhou et al., *Peer-to-Peer Networking and Applications*, 2024), hidden-policy and policy-hiding CP-ABE for medical data (Yang and Liu, *IET Information Security*, 2024; Ding et al., *IEEE J. Biomed. Health Inform.*, 2026), holder-controlled access to claims in self-sovereign identity (Buccafurri et al., *Blockchain: Research and Applications*, 2024), zero-knowledge anonymous authentication of patients (Madine et al., *Array*, 2025), and a survey of zero-knowledge proofs for blockchain privacy (Shashidhara et al., *Security and Privacy*, 2024).

**Retained older sources.** The remaining entries in the reviewer's list are the original constructions or the standards the manuscript builds on, for which no newer source is the appropriate citation: Groth16 [18] is the proof system deployed; Zerocash, Zeth, and AZTEC [7, 8, 19] are the transaction-privacy systems the Introduction contrasts with; CP-ABE, PRE, and functional encryption [10, 16, 17, 21] are the primitives whose disclosure properties the Background discusses (now paired with the 2024–2026 systems above); Plonk and LegoSNARK [26, 27] are the reusable proving systems of the Related Work; Ekiden [23], the XACML privacy work [24], and multi-party policy evaluation [25] are the representative designs of their respective lines; and ICD-10 [14], the GA4GH consent codes [15], OBI [30], and the Jaccard index [31] are the standards and definitions the evaluation uses. We kept them for that reason and cite them for that reason only.

**Format.** The AZTEC entry is now a properly formatted technical whitepaper with its URL and access date, the Zeth entry an arXiv e-print with identifier, and the Ibraimi et al. entry a University of Twente technical report (the submitted version carried a wrong journal name); all new entries include DOIs.

**Location in the revised manuscript:** Section "Background," first paragraph; Section "Related Work," hidden-policy and SSI paragraphs; reference list.